

**Broken Authentication**

# Introduction

## What is authentication ?

Authentication is the process of determining whether someone or something is who or what they say they are.

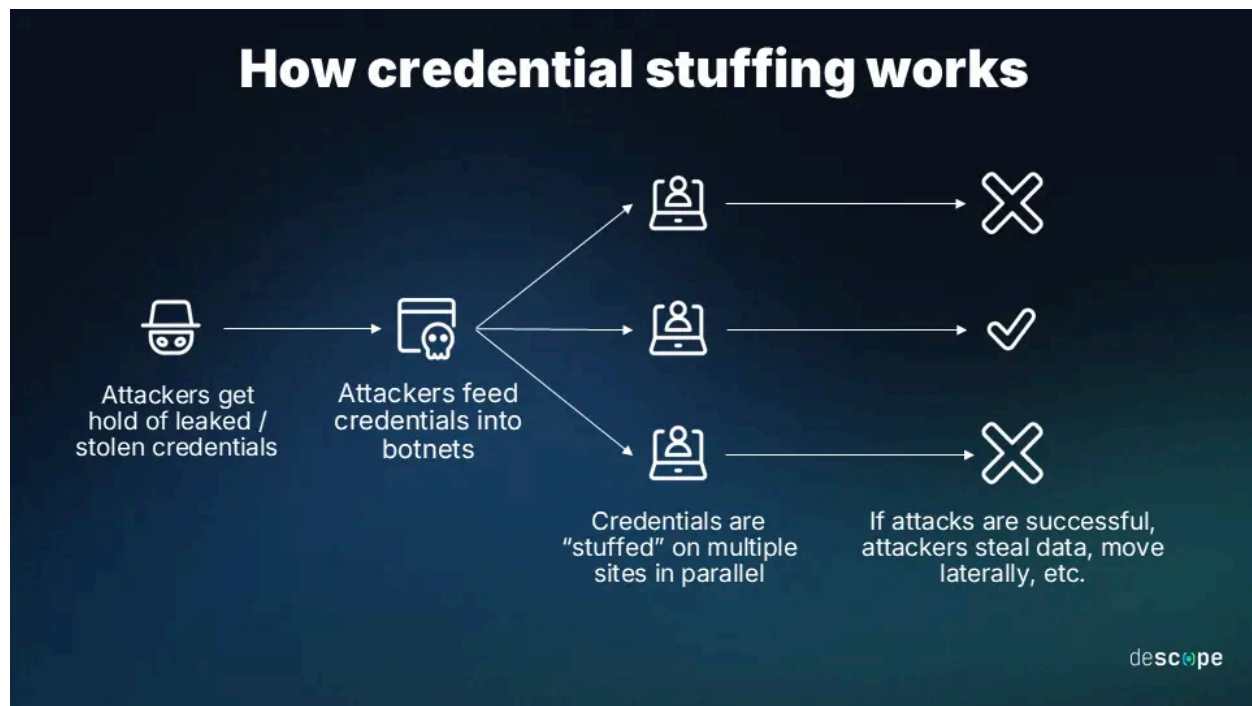
In other words, authentication is the process of verifying that an individual, an entity, or a website is who it claims to be.

## What is Broken Authentication?

Broken authentication is a critical security vulnerability occurring when applications improperly manage user sessions or identity verification, allowing attackers to hijack accounts, steal credentials, or gain unauthorized access.

## Types of Broken Authentication

- **Credential Stuffing**
  - Attackers often sell or share unencrypted email and password lists, which are then used in brute-force attacks via botnets to test credentials across multiple accounts. This is successful because many people reuse passwords across various applications.



- **Weak Auth-token generation**

- An authentication token should ideally be generated with pure randomness. If, on the other hand, it is generated via pseudo-randomness, then it becomes possible for the attackers to reverse engineer the algorithm and predict the consecutive tokens.

## What are the impacts of Broken Authentication ?

- For an end-user, a broken authentication attack could mean illegal access to their account.
- Valuable information of the organization could be leaked.

# Case Study

## The Vulnerability (Broken Authentication)

Several web applications and websites use weak session management to track a user's authenticated status. A common vulnerability occurs when a server uses a predictable or sequential pattern to generate session tokens or when it relies solely on user-controlled input to determine access to sensitive data without proper authorization checks. This is often an instance of Insecure Direct Object Reference (IDOR) combined with insufficient authentication checks.

## The attack

Consider an attacker, Alice, who creates an account on an E-commerce site.

Alice logs in and notices that her profile page url looks like

<https://shop.example.com/profile?id=101>

The number 101 is her sequential user ID.

Alice notices that the system is not checking if the authenticated user is the owner of the profile being viewed. She manually changes the URL parameter from id=101 to id=102, hoping to view the profile of the next user, Bob.

Due to **Broken Authentication**, the server retrieves and displays Bob's personal data, including his name, address and purchase history.

## Result

The attack results in an authorized access to sensitive user data and a privacy breach. The company suffers a huge loss of user trust, faces backlashes and fines for data loss.

## Mitigations

- **Enforcing multi-factor authentication**
  - Multi-factor authentication means an attacker has to bypass two or more layers of authentication which is extremely hard given that most multi-factor authentication mechanisms require access to physical devices such as the phone or the target's fingerprint.
- **Implementing strong password policies**
  - When the password is strong, and has used alphabets, numbers and symbols, it becomes infinitely harder for the attacker to brute force it. Also, longer the password, more secure the account.
- **Generating unpredictable session IDs**
  - Using real randomness to (cryptographically safe randomness) is necessary to generate unpredictable session IDs or any IDs for that matter.

# Conclusion

Broken Authentication remains a critical vulnerability that attackers can exploit to hijack accounts, steal credentials, and gain unauthorized access to sensitive data. Effective mitigation requires a multi-layered approach, focusing on implementing robust security measures. Key defenses include enforcing multi-factor authentication, generating cryptographically unpredictable session IDs, implementing strong password policies, and, crucially, performing strict authorization checks to ensure a user can only access the data they own. By adopting these measures, organizations can significantly reduce the risk of a broken authentication attack and protect user trust.

# References

<https://www.geeksforgeeks.org/ethical-hacking/broken-authentication-vulnerability/>

<https://auth0.com/blog/what-is-broken-authentication/>

<https://owasp.org/API-Security/editions/2023/en/0xa2-broken-authentication/>